

Turla 变种针对 Microsoft Outlook 后门发起 C&C 攻击

[2018-08-24 绿盟科技 CC 攻击](#), [Microsoft Outlook 后门](#), [Turla 变种](#), [恶意脚本](#), [恶意软件](#)

近日，ESET 研究人员发布了关于 APT 组织 Turla（或称 Snake 或 Uroburos）所使用后门的研究报告，该后门用于获取至少三个欧洲国家当局的敏感通信。

后门最近的目标是 Microsoft Outlook。该后门并不使用传统的命令和控制（C&C）方式，例如基于 HTTP（S），而是通过电子邮件附件中的特制 PDF 文件，指示受感染的机器执行一系列命令。命令包括数据泄露、下载其他文件以及执行其他程序和命令。数据泄露本身也通过 PDF 文件进行。

背景

Turla 是俄罗斯网络间谍 APT 组织（也被称为 Snake 或 Uroburos），自 2008 年以来一直活跃于攻击政府机构与民间企业。其中值得注意的受害者是 2013 年芬兰外交部，2014 年至 2016 年瑞士军事公司 RUAG，以及最近于 2017 年底至 2018 年初的德国政府。此前已经有报道发布了一些关于攻击者使用的攻击方式：他们使用电子邮件附件来控制恶意软件，并从系统中传输被盗数据。但是没有公开关于此后门的技术信息。为此，ESET 研究人员发布了 Turla 后门的深入分析。

ESET 的调查还显示，针对 Microsoft Outlook 的这一后门被用于对抗各种政治和军事组织。能够确定其他两个欧洲政府的外国办事处和一个大型国防承包商都受到了损害。同时还发现了 Turla 为此活动注册的数十个电子邮件地址，用于接收受害者的详细数据。

该后门可能最早在 2009 年出现。多年来，其作者一直在添加各种功能，最终赋予它一种罕见的隐身能力和恢复力。以下是过去几年后门的演变过程。

攻击流程

Turla Outlook 后门主要有两个功能。首先，它通过将所有发送的电子邮件转发给攻击者来窃取信息。它主要针对 Microsoft Outlook，但也针对 The Bat!，一个在东欧很受欢迎的邮件客户端。其次，使用电子邮件消息作为其命令和控制（C&C）协议的传输层。数据（例如通过后门命令请求的文件）附加到电子邮件的特制 PDF 文档中，并且命令也在 PDF 附件中接收。因此，它的行为特别隐蔽。值得注意的是，PDF 阅读器和 Outlook 中都没有使用漏洞。实际上是恶意软件能够解码 PDF 文档中的数据并将其解释为后门的命令。

最新版本后门是一个独立的动态链接库（DLL），它具有安装自身并与邮件客户端 Outlook 和 The Bat! 交互的代码。

后门安装：

为了安装后门，攻击者执行名为 Install 的 DLL 导出或使用 regsvr32.exe 注册它。参数是目标邮件客户端。

Microsoft Outlook：

Turla 开发人员再一次依赖 COM 对象劫持来为他们的恶意软件建立持久性。包括通过修改 Windows 注册表中相应的 CLSID 条目来重定向目标应用程序使用的 COM 对象。一旦进行了修改，每次 Outlook 加载此 COM 对象时都会加载后门 DLL。此 COM 重定向不需要管理权限，因为它仅适用于当前用户。最后，使用 COM 劫持允许后门保持隐蔽性。

与邮件客户端的交互：

Microsoft 维护一个 API，即消息应用程序编程接口（MAPI），它允许应用程序与 Outlook 进行交互。此 Turla 后门利用 API 来访问和管理受感染系统的人员的邮箱。首先，它使用 MAPILogonEx 连接到消息传递系统。Outlook 使用标志 MAPI_ALLOW_OTHERS 打开默认会话。因此，后门将使用此先前打开的会话来访问默认邮箱配置文件。完成此操作后，它可以访问完整邮箱，并可以使用其他 MAPI 功能轻松管理。它将遍历各种消息存储库，解析电子邮件并在收件箱和发件箱中添加回调。

收件箱回调：

收件箱回调首先记录有关传入电子邮件的元数据。这包括发件人，收件人，主题和附件名称。然后，解析电子邮件及其附件，以检查它们是否包含来自攻击者的命令。最后，通过检查传入的电子邮件是否包含运营商的电子邮件地址来拦截非传递报告（NDR）电子邮件。因此，任何包含运营商电子邮件地址的电子邮件将被丢弃。

发件箱回调：

与收件箱回调类似，发件箱回调会记录每封外发电子邮件的元数据。它还会将每封外发电子邮件转发给攻击者的电子邮件地址。后门会定期向攻击者的电子邮件地址发送报告。

隐藏恶意行为：

由于后门在用户使用计算机和 Outlook 的同时工作，因此会努力隐藏可能出现在屏幕上的各种恶意行为，例如来自攻击者的电子邮件。首先，后门总是删除发送给攻击者或从攻击者收到的所有电子邮件。其次，hook 住 CreateWindowsEx 函数。阻止创建 NetUIHWND 类型的窗口，该窗口是 Outlook 用于显示在屏幕右下角通知的窗口类型。

结论

据 ESET 调查，Turla 是目前唯一一个使用完全由电子邮件控制的后门的间谍组织，更具体地说是通过 PDF 附件控制。虽然 Turla 后门不是第一个使用受害者的真实邮箱接收

命令和泄露数据的后门，但它是第一个使用标准 API（MAPI）与 Microsoft Outlook 进行交互的公知后门。这是对旧邮件控制后门的一个重大改进，旧后门依赖 Outlook Express，只是读取收件箱文件和写入发件箱文件。相比之下，Turla 后门甚至可以与最新版本的 Outlook 一起使用。

受到破坏的组织不仅有被种植后门的 Turla 监视的风险，而且还有被其他攻击者监视的风险。后门只是执行它收到的任何命令，而无法识别操作符。因此，其他攻击者可能已经对后门进行了逆向工程并找出了如何控制它，甚至还在利用后门对受害者进行间谍活动。

详细信息可参考：

<https://www.welivesecurity.com/2018/08/22/turla-unique-outlook-backdoor/>

IOC

Hashes

SHA1 hash	Component	Compilation Time (GMT)	ESET Detection Name
8A7E2399A61EC025C15D06ECDD9B7B37D6245EC2	Backdoor	2013-06-28 14:15:54	Win32/Turla.N
F992ABE8A67120667A01B88CD5BF11CA39D491A0	Dropper	2014-12-03 20:50:08	Win32/Turla.AW
CF943895684C6FF8D1E922A76B71A188CFB371D7	Backdoor	2014-12-03 20:44:27	Win32/Turla.R
851DFFA6CD611DC70C9A0D5B487FF00BC3853F30	Backdoor	2016-09-15 08:14:47	Win32/Turla.DA

Filenames

- %appdata%/Microsoft/Windows/scawrdot.db
- %appdata%/Microsoft/Windows/flobcsnd.dat
- mapid.tlb

Registry Keys

- HKCU\Software\Microsoft\Windows\CurrentVersion\Settings\ZonePolicy\
- HKCU\Software\Classes\CLSID\{49CBB1C7-97D1-485A-9EC1-A26065633066}
- HKCU\Software\Classes\CLSID\{84DA0A92-25E0-11D3-B9F7-00C04F4C8F5D}